Phishing Incident Compromise

Date: 2026-10-08

Executive Summary

On September 26, 2026, the Accounts Department notified the Security Operations Center of a suspected phishing email originating from an internal email account. An investigation confirmed that Abigail Smith's email account had been compromised following a phishing attack. The attacker subsequently used the compromised account to distribute additional phishing emails to internal users.

At the time of reporting, the extent of user interaction with the malicious links remained unknown, as did whether malware had been installed on affected endpoints. Affected users were contacted to determine whether they had downloaded files or disclosed credentials or other sensitive information through websites associated with the phishing campaign.

Containment measures included resetting affected user accounts, blocking the email address and IP address associated with the campaign, scanning affected endpoints for malware, and monitoring the internal network for suspicious activity.

Approximately 767 internal user accounts were targeted during the incident. The preliminary financial impact is estimated at $4,000, covering investigation, containment, remediation, and eradication costs. The investigation remains ongoing to determine the full scope of the incident, assess potential credential or sensitive information exposure, identify any additional compromised accounts or systems, and validate the estimated financial impact.

Background

On 2026-09-26 at 00:00:00 ET, the SOC Team was notified of a suspicious email sent from Abigail Smith (asmith@northamericanlumbercoalition.com) to Brenda Rogers (brogers@northamericanlumbercoalition.com). The incident involved a suspected phishing attempt, a potentially compromised internal email account, and subsequent phishing activity targeting internal users. The email contained a link to `http://myers.com/login`, which was suspected of being associated with credential-harvesting activity. The initial phishing email associated with the suspected account compromise originated from (jacoblane@roberts.com)

Following notification, the SOC initiated an investigation to determine the email's origin, assess whether the sender's account had been compromised, identify the recipients of related phishing messages, and establish whether any users had interacted with the suspicious link.

Timeline

2026-09-25 at 13:16:25 ET
A malicious email with message ID `7B6BF0ECDC` was sent from `jacoblane@roberts.com`, originating from IP address `85.189.238.171`, to Abigail Smith (`asmith@northamericanlumbercoalition.com`).

2026-09-25 at 15:13:25 ET
Abigail Smith, using IP address `10.10.0.23`, accessed the malicious link `http://myers.com/login` contained in the email, resulting in the suspected compromise of her login credentials.

2026-09-25 at 18:43:26 ET
An unauthorized user logged into Abigail Smith's account from IP address `85.189.238.171` and began sending malicious emails to several internal email addresses.

2026-09-25 at 18:49:26 ET
Several employees began accessing the malicious website `http://myers.com/login`.

2026-09-25 at 19:02:22 ET
Brenda Rogers (`brogers@northamericanlumbercoalition.com`) received an email containing the malicious link from Abigail Smith's compromised account. The email had a message ID `22A0C7DBBB`.

2026-09-26 at 00:00:00 ET
The SOC Team was notified of a suspicious email sent to Brenda Rogers.

2026-09-26 at 01:00:00 ET
The SOC Team began containment efforts by quarantining the malicious email and searching the email environment for messages associated with the phishing campaign.

2026-09-26 at 04:00:00 ET
The SOC Team identified which users had received the malicious email and investigated which users had clicked the link.

2026-09-26 at 05:00:00 ET
The SOC Team blocked the associated email address and IP address, removed matching emails from affected mailboxes, and reset the passwords of affected user accounts.

Findings

1. **Initial phishing email:** A suspicious email was identified with message ID `7B6BF0ECDC`, reportedly sent to Abigail Smith on September 25, 2026.
2. **Suspected credential compromise:** Endpoint 10.10.0.23 accessed the suspected phishing URL, `http://myers.com/login`. Available logs were insufficient to confirm whether credentials were submitted or stolen. Although subsequent unauthorized activity was associated with Abigail Smith's account, the exact method of compromise remains unconfirmed.
3. **Unauthorized account activity:** A login from IP address `85.189.238.171` was associated with subsequent phishing activity using Abigail Smith's account.
4. **Scope:** The phishing campaign targeted approximately 767 internal user accounts with malicious emails. Approximately 205 users visited the malicious link contained in the email
5. **Outstanding impact assessment:** The number of users who submitted credentials, downloaded files, or experienced unauthorized access remains unconfirmed

Actions Taken

1. Initial Investigation and Email Analysis

Following notification on September 26, 2026, the Security Operations Center initiated an investigation into the suspicious email reported by the Accounts Department. The SOC reviewed the identified email, including its sender, recipient, message identifier, and embedded URL, to determine the scope of the phishing campaign and identify related messages.

2. Email Containment and Removal

The SOC quarantined the identified malicious email and searched the email environment for messages associated with the phishing campaign. Matching emails were identified and removed from affected mailboxes to reduce the likelihood of additional users interacting with the malicious link.

3. Identification of Affected Users

The SOC identified approximately 767 internal user accounts targeted by the phishing campaign. Available investigation findings indicated that approximately 205 users had

accessed the malicious URL. These figures were used to assess the potential scope of exposure and prioritize further investigation.

4. Account Containment

The SOC reset the passwords of affected user accounts to reduce the risk of continued unauthorized access.

5. Threat Indicator Blocking

The SOC blocked the email address and IP address associated with the phishing campaign to help prevent further malicious activity. The malicious URL was also identified during the investigation and was blocked through applicable web filtering or security controls where appropriate.

6. Endpoint Investigation and Monitoring

Affected endpoints were identified for investigation to determine whether users had downloaded suspicious files or whether there was evidence of malware activity.

7. Credential Exposure Assessment

The investigation could not establish whether users submitted credentials to the suspected phishing website because supporting logs were unavailable. Consequently, credential exposure could not be confirmed or ruled out.

Financial Impact

Item	Cost
Investigation	$2500
Remediation Labor	$1500
Total	**$4000**

Investigation: 20 hours × $125/hour = $2,500

Remediation labor: 10 hours × $150/hour = $1,500

Total preliminary cost: $4,000

Lessons Learned

1. **Employee Awareness Is Critical:** The incident demonstrated that phishing emails can deceive employees and lead to account compromise. Employees must be able to recognize suspicious links, identify credential-harvesting websites, and report phishing attempts promptly.

2. **A Compromised Account Can Spread Phishing Internally:** The attacker used Abigail Smith's compromised account to distribute additional phishing emails to internal users. This highlights the risk that a single compromised account can become a starting point for a broader campaign.

3. **Early Detection and Reporting Are Essential:** Prompt reporting of suspicious emails enables the SOC to investigate malicious activity and initiate containment before additional users are affected. Delays in reporting can increase the potential scope of an incident.

4. **Account Compromise Requires a Coordinated Response:** Password resets and email containment are important, but the response must also consider active sessions, suspicious sign-ins, potential credential exposure, and possible compromise of other accounts or endpoints.

5. **Accurate Impact Assessment Is Necessary:** Although approximately 767 internal accounts were targeted and 205 users reportedly visited the malicious link, the number of users who submitted credentials or experienced further compromise remained unconfirmed. This demonstrates the importance of collecting and correlating reliable evidence to establish the full impact.

6. **Incident Documentation and Cost Tracking Matter:** Maintaining accurate timelines, evidence, remediation records, and investigation hours supports effective incident reviews, management reporting, and future improvements to security operations.

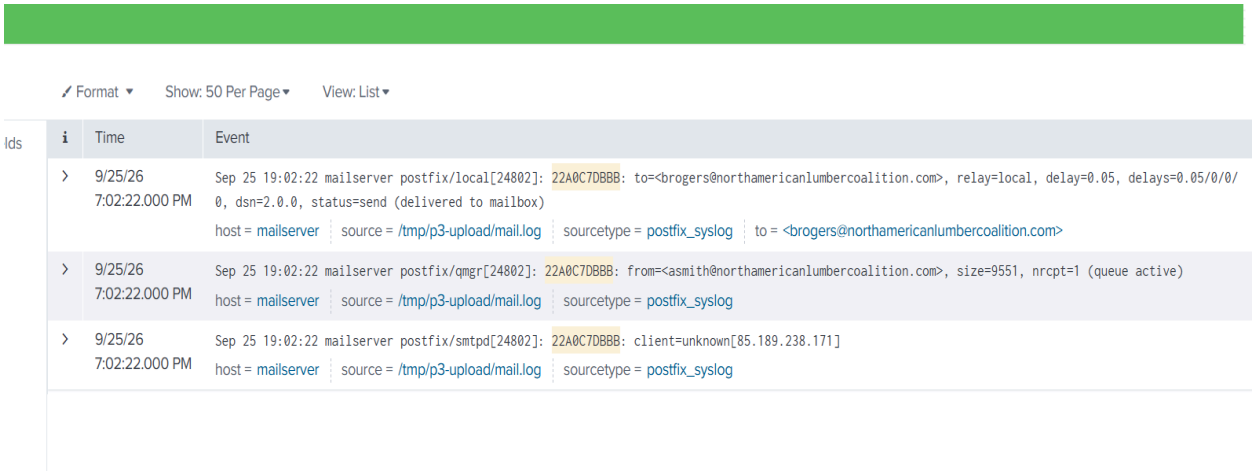
Opportunities for Improvement

1. **Strengthen Email Security Controls:** Review and improve email filtering, anti-phishing protections, and sender authentication controls to help detect suspicious messages and reduce email spoofing.
2. **Enforce Multi-Factor Authentication (MFA):** Require MFA for email and other critical accounts. Review authentication policies and implement risk-based controls where available to reduce the risk of unauthorized access following credential theft.
3. **Improve Security Monitoring and Detection:** Configure alerts for unusual login locations, suspicious authentication attempts, abnormal email-sending volumes, and access to known malicious URLs. Correlate email, identity, endpoint, DNS, and proxy logs to identify related activity more quickly.
4. **Enhance Incident Response Procedures:** Develop and maintain a phishing incident response playbook covering email quarantine, malicious message removal, account password resets, session revocation, endpoint investigation, user notification, and post-containment validation.
5. **Improve Investigation and Exposure Assessment:** Establish a repeatable process for identifying all targeted recipients, validating link clicks, investigating potential credential submission, scanning affected endpoints, and determining whether other accounts or systems were compromised.
6. **Expand Security Awareness Training:** Conduct regular phishing simulations and targeted training to help employees recognize malicious emails, avoid suspicious links, and report potential security incidents promptly.

7. **Improve Threat Indicator Management:** Record and validate malicious URLs, IP addresses, sender addresses, and email message identifiers. Use these indicators to search across security systems for related activity and block confirmed threats where appropriate.

Appendix

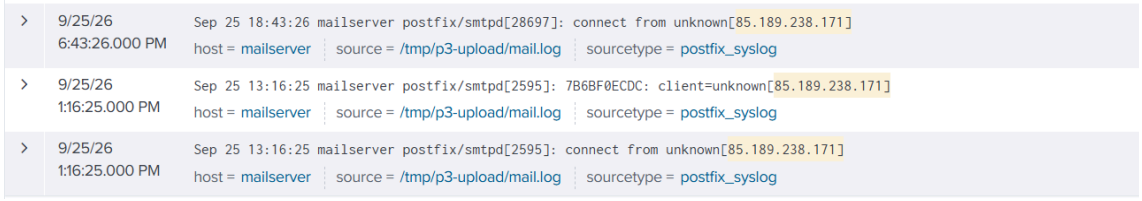
Image showing logs for the phishing email reported to the S0C department



Format ▾ Show: 50 Per Page ▾ View: List ▾

i	Time	Event
›	9/25/26 7:02:22.000 PM	Sep 25 19:02:22 mailserver postfix/local[24802]: 22A0C7DBBB: to=<brogers@northamericanlumbercoalition.com>, relay=local, delay=0.05, delays=0.05/0/0/0, dsn=2.0.0, status=send (delivered to mailbox) host = mailserver | source = /tmp/p3-upload/mail.log | sourcetype = postfix_syslog | to = <brogers@northamericanlumbercoalition.com>
›	9/25/26 7:02:22.000 PM	Sep 25 19:02:22 mailserver postfix/qmgr[24802]: 22A0C7DBBB: from=<asmith@northamericanlumbercoalition.com>, size=9551, nrcpt=1 (queue active) host = mailserver | source = /tmp/p3-upload/mail.log | sourcetype = postfix_syslog
›	9/25/26 7:02:22.000 PM	Sep 25 19:02:22 mailserver postfix/smtpd[24802]: 22A0C7DBBB: client=unknown[85.189.238.171] host = mailserver | source = /tmp/p3-upload/mail.log | sourcetype = postfix_syslog

Image showing Initial Phishing Email



›	9/25/26 6:43:26.000 PM	Sep 25 18:43:26 mailserver postfix/smtpd[28697]: connect from unknown[85.189.238.171] host = mailserver | source = /tmp/p3-upload/mail.log | sourcetype = postfix_syslog
›	9/25/26 1:16:25.000 PM	Sep 25 13:16:25 mailserver postfix/smtpd[2595]: 7B6BF0ECDC: client=unknown[85.189.238.171] host = mailserver | source = /tmp/p3-upload/mail.log | sourcetype = postfix_syslog
›	9/25/26 1:16:25.000 PM	Sep 25 13:16:25 mailserver postfix/smtpd[2595]: connect from unknown[85.189.238.171] host = mailserver | source = /tmp/p3-upload/mail.log | sourcetype = postfix_syslog